Trust Center

Our security posture and compliance commitment

Compliance Status

- GDPR Compliant — Data privacy
- SOC 2 Type II — Target Q3 2027
- Azure Certified — Infrastructure
- ISO 27001 — Planned 2028

Encryption

In Transit: All data in transit is encrypted using TLS 1.2 or higher. HTTP connections are automatically redirected to HTTPS.

At Rest: Database records and backups are encrypted with AES-256. Encryption keys are managed separately using Azure Key Vault.

Access Control

- Authentication: Multi-factor authentication (MFA) via Microsoft Entra ID (Azure AD)
- Authorization: Role-based access control (RBAC) enforced at application and database layers
- SSO: SAML 2.0 single sign-on available for Enterprise customers via WorkOS
- Session Management: Sessions expire after 24 hours of inactivity; forced re-authentication for sensitive operations

Infrastructure & Availability

- Primary Cloud Provider: Microsoft Azure (certified for HIPAA, FedRAMP, SOC 2)
- Active physical region: single deployment in Azure West US 2
- Database: managed MySQL in Azure with automatic backups
- Cache: Azure Managed Redis (Balanced_B3) with high availability enabled and private access
- Perimeter: Cloudflare as CDN/WAF in front of the Azure origin
- Disaster Recovery: Geo-redundant backups; RTO < 4 hours, RPO < 1 hour
- SLA: 99.9% uptime SLA for paid plans (excludes scheduled maintenance)

Audit & Monitoring

- Audit Logs: All user actions, API calls, and data access are logged and retained for 7 years
- Monitoring: Real-time security monitoring using Azure Security Center; alerts for suspicious activity
- Intrusion Detection: Network intrusion detection and prevention enabled on all endpoints

Subprocessors

We partner with industry-leading providers for specific services:

Processor	Purpose	Location
Microsoft Azure	Compute, Storage, Networking, AI inference (Azure OpenAI)	Azure West US 2
Paddle	Payment Processing	US/UK
WorkOS	Authentication & SSO	US
Google Gemini AI	Optional LLM Services	US

Incident Response

- Response Time: Security incidents are investigated within 2 hours of detection
- Notification: Affected customers are notified within 72 hours of confirmed data breach (per GDPR Art. 33–34)